

Nachmittag 4 – Detect

Logs lesen, Phishing erkennen

Verdächtige E-Mails und Log-Auszüge analysieren – Angriffserkennung im KMU-Alltag

Dauer	50–60 Minuten (inkl. 10 Min. Ergebnisdiskussion im Plenum)
Arbeitsform	Paare oder Gruppen à 3 Personen
Material	Dieses Arbeitsblatt
NIST-CSF-Bezug	Detect: DE.CM (kontinuierliche Überwachung), DE.AE (Analyse auffälliger Ereignisse)

Lernziele

- Typische Phishing-Merkmale systematisch erkennen (Absender, Links, Druck, Kontext).
- Einfache Log-Auszüge (M365-Anmeldungen, Windows-Ereignisse) lesen und Auffälligkeiten benennen.
- Für das eigene KMU festlegen, welche wenigen Ereignisse zwingend überwacht werden sollten.

Ausgangslage

Sie unterstützen die Muster Metallbau AG (unser Fallstudien-KMU, 45 MA) als „Sicherheits-Spürnase“. Nach der MFA-Einführung aus Nachmittag 3 landeten drei E-Mails und zwei Log-Auszüge auf Ihrem Tisch.

Aufgabe A – Drei E-Mails im Posteingang der Buchhaltung (ca. 20 Min.)

Beurteilen Sie jede E-Mail: Phishing/Betrug oder legitim? Markieren bzw. notieren Sie mindestens drei konkrete Merkmale, die Ihre Einschätzung stützen, und legen Sie fest, was die Empfängerin tun soll.

E-Mail 1 Von: "Peter Muster – Geschäftsführung" <p.muster@rnuster-metallbau.ch> An: Buchhaltung <buchhaltung@muster-metallbau.ch> Betreff: DRINGEND – Vertrauliche Zahlung heute Gesendet: Freitag, 16:47 Uhr — Guten Tag, ich bin bis am Abend in Sitzungen und telefonisch nicht erreichbar. Bitte überweisen Sie noch heute CHF 23 400 an den neuen Lieferanten (IBAN im Anhang). Es geht um eine vertrauliche Firmenübernahme – bitte mit niemandem darüber sprechen. Bestätigen Sie mir die Ausführung kurz per E-Mail. Beste Grüsse, P. Muster	
Einschätzung	
Merkmale (min. 3)	
Empfehlung	

E-Mail 2

Von: "Microsoft 365 Admin" <security-noreply@m365-secure-check.com>

An: k.beispiel@muster-metallbau.ch

Betreff: Ihr Postfach wird in 24 Stunden gesperrt

—

Ihre Mailbox hat das Speicherlimit erreicht. Um eine Sperrung zu verhindern, bestätigen Sie Ihr Konto innert 24 Stunden: <https://m365-secure-check.com/verify?user=k.beispiel> — Nach der Bestätigung wird Ihr Speicher automatisch erweitert. Microsoft 365 Support Team

Einschätzung	
Merkmale (min. 3)	
Empfehlung	

E-Mail 3

Von: "Schmid Transporte AG – Rechnungswesen" <rechnung@schmid-transporte.ch>

An: buchhaltung@muster-metallbau.ch

Betreff: Rechnung 2026-0457 – Transport Auftrag 8812

—

Sehr geehrte Damen und Herren, anbei die Rechnung für den Transport vom 12.07.2026 (Auftrag 8812, Baustelle Beispielstrasse 5). Zahlbar innert 30 Tagen wie vereinbart. Freundliche Grüsse, R. Schmid — Anhang: Rechnung_2026-0457.pdf (Hinweis: Auftrag 8812 existiert im ERP; Schmid ist langjähriger Transportpartner; IBAN identisch mit bisherigen Zahlungen.)

Einschätzung	
Merkmale	
Empfehlung	

Aufgabe B – Zwei Log-Auszüge (ca. 20 Min.)

Log 1: Microsoft-365-Anmeldeprotokoll (Auszug, Benutzerin k.beispiel)

Zeit (MESZ)	Standort / IP	App	MFA	Ergebnis
Mo 07:58	Musterhausen, CH (83.78.x.x)	Outlook (Desktop)	erfüllt	Erfolg
Mo 12:15–12:19	Lagos, NG (105.112.x.x)	Browser	—	Fehler: falsches Passwort (23 Versuche)
Mo 12:21	Lagos, NG (105.112.x.x)	Browser	—	Fehler: falsches Passwort
Mo 12:24	Lagos, NG (105.112.x.x)	IMAP (Legacy- Protokoll)	nicht unterstützt	Erfolg
Mo 13:02	Musterhausen, CH (83.78.x.x)	Teams	erfüllt	Erfolg
Mo 13:05	Lagos, NG (105.112.x.x)	IMAP (Legacy- Protokoll)	nicht unterstützt	Erfolg – neue Posteingangsregel erstellt: „Alle Mails an extern- archiv@getmail- box.com weiterleiten, danach löschen“

Fragen:

- Was ist hier passiert? Beschreiben Sie den Ablauf in 2–3 Sätzen.
- Warum hat MFA den Zugriff um 12:24 Uhr nicht verhindert?
- Welche zwei Sofortmassnahmen ordnen Sie an?

Log 2: Windows-Ereignisprotokoll des Dateiservers (Auszug, vereinfacht)

Zeit	Ereignis-ID	Beschreibung
Di 02:11	4625	Anmeldefehler, Konto: administrator, Quelle: 192.168.1.243 (PC-WERKSTATT-03) – 1. von 212 gleichartigen Ereignissen bis 02:39
Di 02:41	4624	Anmeldung erfolgreich, Konto: administrator, Quelle: PC-WERKSTATT-03
Di 02:44	4720	Benutzerkonto erstellt: „svc_backup2“ (Ersteller: administrator)
Di 02:45	4732	„svc_backup2“ zur Gruppe „Administratoren“ hinzugefügt
Di 02:52	7045	Neuer Dienst installiert: „WinUpdateSvc“, Pfad: C:\Users\Public\wupd.exe
Di 03:10	1102	Sicherheitsprotokoll wurde gelöscht (Konto: svc_backup2)

Fragen:

- Rekonstruieren Sie die Angriffskette Schritt für Schritt. Welches Ereignis ist das alarmierendste?
- Um welche Uhrzeit hätte ein Alarm spätestens ausgelöst werden müssen – und durch welches Ereignis?
- Was bedeutet es, dass der Ausgangspunkt PC-WERKSTATT-03 ist?

Aufgabe C – Minimal-Monitoring für die Muster AG (ca. 10 Min.)

Ein SOC ist für 45 Mitarbeitende nicht realistisch. Definieren Sie die fünf Ereignisse/Alarmer, die die Muster AG mit Bordmitteln (M365-Warnungen, TechPartner) mindestens überwachen sollte – und wer den Alarm erhält.

Nr.	Ereignis / Alarm	Wer erhält die Meldung?
1		
2		
3		
4		
5		

Diskussionsfragen fürs Plenum

- Woran hätte man Log 1 und Log 2 im Alltag der Muster AG tatsächlich bemerkt – ehrlich betrachtet?
- Ab wann lohnt sich für ein KMU ein externer Überwachungsdienst (MDR/„SOC as a Service“)?